Clase 9 · Metasploit y escaneo con Nmap

Administración de Servicios de Internet · Mtro. Juan Ángel Calvillo Pérez · lunes 28 sep 2026 · Ciberseguridad ofensiva · Apuntes y resumen de estudio

PARTE 1 · Apuntes completos

Uso académico de recolección de información, no malicioso.

1. Repaso: Kali Linux y Metasploit

- **Kali Linux:** sistema operativo enfocado en ciberseguridad. **Metasploit:** framework; se trabaja con módulos `auxiliary`, el objetivo en la variable **RHOSTS** (Remote Host) y se verifica con `show options`.
- La IP auditada indica si los servicios están concentrados en un servidor local (Apache, Tomcat) o en la nube. La UNAM usa protección perimetral (Cloudflare) porque ya sufrió ataques.

2. Encabezados HTTP e infraestructura

- En implementaciones débiles **todos los servicios corren en una sola máquina**: riesgo crítico de disponibilidad (sin redundancia).
- Escaneando directorios y encabezados del IPN, Metasploit devolvió **HTTP 404** y se quedó reintentando: la infraestructura está tras **Microsoft Azure**, cuya protección perimetral bloquea el escaneo. Ahí Metasploit solo sirvió para ver puertos abiertos.

Error común: creer que el 404 es falla de la herramienta; es la nube bloqueando.

3. Nmap

Antes de escanear, revisar la red propia con `ip a`:

- **eth0:** interfaz Ethernet (física o virtual) hacia la red o internet.
- **lo (loopback):** 127.0.0.1, el sistema hablando consigo mismo.

La VM de Kali tenía **192.168.139.132**: el segmento 192.168.x.x es **privado de Clase C**.

Comando	Propósito
`nmap [IP]`	Escaneo básico de puertos TCP (detectó 4 hosts en 8 s, NetBIOS 445, MAC)
`nmap -sn [segmento]`	**Ping sweep**: solo qué hosts están up/down, sin puertos
`nmap [IP]/24`	CIDR /24 = 255.255.255.0: las 254 direcciones del segmento, con latencia y MAC
`nmap -sS [IP]`	**SYN scan sigiloso**: manda SYN, recibe SYN-ACK y **no completa** el saludo (sin ACK); no queda en los logs convencionales
`nmap -sV [IP]`	Versión del servicio en cada puerto
`nmap -O [IP]`	Sistema operativo por las respuestas del stack TCP/IP
`nmap -A [IP]`	Agresivo: -O + -sV + scripts (-sC) + traceroute; muy detectable

Puerto	Servicio
21	FTP
22	SSH
23	Telnet
25 / 110 / 143	SMTP / POP3 / IMAP
80 / 443	HTTP / HTTPS
445	Microsoft-DS / NetBIOS
1521	Oracle
3306	MySQL / MariaDB

4. Automatización con Bash y Python

- **Bash:** intérprete que ejecuta scripts `.sh` a nivel de sistema operativo.
- Estrategia: un script que lance `nmap -sS` con un **cron job** (p. ej. cada hora) y genere un reporte si se abre un puerto nuevo; integrado con **Python** para procesar la salida y mandar alertas en tiempo real (WhatsApp, SMS).

5. Práctica individual: una herramienta de Kali

- Cada alumno elige una herramienta, la investiga y documenta paso a paso en "Resultados".
- **Prohibidas:** Metasploit, Nmap, Wireshark, análisis básico de redes y herramientas descontinuadas.
- Mencionadas: **Medusa** (fuerza bruta de credenciales), **Maltego** (OSINT), **OpenVAS** (escáner de vulnerabilidades), **NetExec** (antes CrackMapExec, Active Directory), **John the Ripper** (contraseñas).
- Dificultad: forense de discos (Autopsy) y cracking Wi-Fi (antenas con packet injection) son más complicadas; escaneo, servicios y fuerza bruta son más accesibles. Fechas: verificar en Classroom.

PARTE 2 · Resumen para estudiar

Versión corta de lo que más probablemente se pregunta. Léela primero y vuelve a la Parte 1 si algo no queda claro.

Nmap (examen)

`-sn` ping sweep (sin puertos) · `/24` segmento completo · `-sS` SYN sigiloso (sin ACK final) · `-sV` versiones · `-O` sistema operativo · `-A` agresivo (todo junto).

Concepto	Para recordar
eth0 vs. lo	Red real vs. 127.0.0.1
192.168.x.x	Privada Clase C
RHOSTS	Objetivo en Metasploit
404 con Azure	La nube bloquea el escaneo
Puertos	21 FTP, 22 SSH, 80/443 web, 445 NetBIOS, 1521 Oracle, 3306 MySQL
Automatizar	Bash + cron + Python para alertas